

AHS Vault — UK Enterprise-Ready

What You Can Get INSTANTLY Now + How to Get Each One

B2B SaaS | You-host relay + BYO Google Drive | Finance + NHS + Gov | UK Ltd exists | Date: 2026-09-11

This guide covers only the documents from the 71-item checklist (**ENTERPRISE_DOCS_CHECKLIST.txt**) that you can produce **today from this repo**, without waiting for an auditor, government body, or paid certificate. For each one: **what it is, where the source data lives in your code, and the exact steps/commands to create it.**

How to read this PDF: PART A = fully generatable now (minutes–hours). PART B = you can draft now but it is NOT final until a solicitor / DPO signs it. PART C = do NOT chase now — these need external audits and will fail until code gaps are fixed (plaintext :8080, CORS *, leaked Tauri key, plaintext onboarding.json, IMAP full-body fetch).

PART A — Fully generatable NOW (no external authority)

These are built directly from files you already have. No payment, no waiting, no auditor.

#8	LICENSE file	DO NOW — hours
----	--------------	----------------

Why: you claim MIT in README.md:5,420 but LICENSE does not exist. Enterprise legal blocks you on day one.

How to get it — step by step:

- Decide: proprietary commercial (recommended for B2B) or MIT.
- Create file G:\ahs\ahs-app\LICENSE with the licence text.
- Fix package.json (vault-web-auth + vault-desktop-tauri): remove "private":true OR add "license" field to match.
- Add license= to src-tauri/Cargo.toml.
- Fix README badge link to .LICENSE.

Source in your repo: Vault source: README.md:5,420 | vault-web-auth/package.json | vault-desktop-tauri/package.json + src-tauri/Cargo.toml | vault-backend-go/go.mod

#13	Third-Party Notices + SBOM (CycloneDX/SPDX)	DO NOW — hours
-----	---	----------------

Why: finance/NHS procurement asks for SBOM first. You have all manifests already, just never generated the SBOM.

How to get it — step by step:

- Web: cd vault-web-auth && npm install && npm run sbom (or: npx @cyclonedx/cdxgen -o sbom-web.json)
- Desktop JS: cd vault-desktop-tauri && npx @cyclonedx/cdxgen -o sbom-desktop.json
- Rust: cargo install cargo-cyclonedx && cd vault-desktop-tauri/src-tauri && cargo cyclonedx -o sbom-rust.json
- Go: cd vault-backend-go && go install github.com/CycloneDX/cyclonedx-gomod/cmd/cyclonedx-gomod@latest && cyclonedx-gomod mod -json -output sbom-go.json
- Android: cd vault-mobile-auth && ./gradlew cyclonedxBom (with org.cyclonedx.bom plugin) OR list from app/build.gradle.kts
- Merge + save as docs/SBOM/ + build NOTICE file from licences found.

Source in your repo: Vault source: vault-web-auth/package.json | vault-desktop-tauri/package.json | src-tauri/Cargo.toml | vault-backend-go/go.mod | vault-mobile-auth/app/build.gradle.kts

#40	Executive Whitepaper + Crypto Design Spec (draft)	DO NOW — hours
-----	---	----------------

Why: every CISO asks 'how does zero-knowledge actually work?'. All primitives are in code + README:230-258.

How to get it — step by step:

- Copy crypto table from README.md:230-258 (AES-256-GCM 128KB blocks, BIP-39 24-word, X25519+AES-GCM transport, Ed25519 desktop, ECDSA P-256 mobile/web, PBKDF2 310k, SHA-256).

- Add key-lifecycle diagram: mnemonic -> seed[0..32]=master, seed[32..64]=Ed25519, SHA256(seed)=X25519 (crypto.rs) -> pairing QR nonce 5-min (hub.go:77-97) -> unlock push_relay (handlers.go:684-731) -> FUSE/WebDAV mount (fs.rs).
- Document wire format: base64(32B peer PK || 12B nonce || ct+tag) from crypto.rs + crypto.ts + CryptoManager.kt.
- Note known parity bug: web PBKDF2-310k vs mobile single SHA-256(salt||pin) — record as open issue.
- Export as docs/WHITEPAPER.md + PDF (2-page exec + 15-page spec).

Source in your repo: Vault source: src-tauri/src/crypto.rs | vault-web-auth/src/lib/crypto.ts | CryptoManager.kt | fs.rs | network.rs | README.md:18-33,230-258 | Project_Overview.txt

#41	System Architecture Document (C4)	DO NOW — hours
-----	-----------------------------------	----------------

Why: buyers need Context/Container/Component/Code views. Your structure is already documented in README:144-224.

How to get it — step by step:

- C1 Context: users, desktop/mobile/web, Go relay, Postgres, Google Drive, GitHub Releases, IMAP server.
- C2 Container: Tauri v2 desktop : FUSE/WebDAV | Go+Chi :8080 + Postgres 15 + Gorilla WS | React 19 web + Dexie | Kotlin+Compose mobile.
- C3 Component: lib.rs / crypto.rs / fs.rs / network.rs / shield.rs / oauth.rs / drive_mirror.rs | router.go / handlers.go / web_handlers.go / db.go / webauthn.go / hub.go / gdrive.go.
- C4 Code: reference file:line for each handler. Save as docs/ARCHITECTURE.md + diagrams (draw.io/Mermaid).

Source in your repo: Vault source: README.md:54-64,144-224 | tauri.conf.json | docker-compose.prod.yml | PROJECT.md

#42	Data Flow Diagrams + Data Residency Map	DO NOW — hours
-----	---	----------------

Why: DPIA + CISO + NHS IG cannot proceed without it. Flows are fully traceable in handlers + gdrive.

How to get it — step by step:

- Flow 1 Upload: shadow blob (AES-GCM) -> POST /api/vault/upload + X-Desktop-PK/X-Signature(SHA256 body)/X-Google-Token -> temp file -> Verify Ed25519 -> Files.Create SecureVault/ -> RecordBlobOwnership.
- Flow 2 Download/Delete/Index/Stats: same signing (sign blobID / body) + ownership check, then GetObject/DeleteObject/GetRootBlob.
- Flow 3 Unlock relay: desktop_register/mobile_register (hub.go:54-75) -> PairVault nonce check -> SendToidentity (opaque to server).
- Map: UK users -> your relay host (record actual: ahs.mayfairmarketing.online — flag: move to eu-west-2 London for regulated pilots) -> Google Drive (US/EU — needs IDTA/TRA) -> GitHub Releases (US). Mark plaintext never leaves device + what server/Google sees (ciphertext + sizes/counts + tokens).

Source in your repo: Vault source: internal/api/handlers.go:396-443,684-731,754,800-875,903 | internal/storage/gdrive.go | internal/websocket/hub.go | src-tauri/src/network.rs + stream_upload/download

#43	Threat Model draft (STRIDE + LINDDUN)	DO NOW — hours
-----	---------------------------------------	----------------

Why: shows you know your gaps before a pen tester finds them. Gaps are already visible in router/handlers.

How to get it — step by step:

- List assets: mnemonic, master key, X25519 secrets, Google refresh_token, blobs, nonces, WS sessions.
- STRIDE rows: Spoofing (self-asserted WS BindIdentity, no sig on RelayPush), Tampering (replayable sigs, no nonce/timestamp), Repudiation (no immutable audit, LogThreat forgeable), Info disclosure (logs leak PK/nonce, Logger logs ?public_key, X-Google-Token in memory), DoS (no rate limit, unbounded temp upload, 1h timeouts), EoP (DeleteDevicesByNameAndOS overly broad, GetStats returns all users if param omitted).
- LINDDUN rows: IMAP full RFC822 fetch (over-collection), Downloads polling, Google Fonts fetch, Drive metadata.
- Save as docs/THREAT_MODEL.md with risk + owner + fix linked to code lines.

Source in your repo: Vault source: router.go:14-34,59-65 | handlers.go:35-38,65-121,191-367,555-575,684-731 | web_handlers.go:17-19 | auth/webauthn.go:34-109 | main.go:48-62 | shield.rs:43

#44	API Specification (OpenAPI)	DO NOW — hours
-----	-----------------------------	----------------

Why: enterprise integrators + pen testers need it. All routes exist in router.go/handlers.go.

How to get it — step by step:

- Enumerate: POST /api/vault/upload | GET /api/vault/download/{id} | POST /api/vault/delete | GET+POST /api/vault/index | POST /api/vault/register | GET /api/vault/devices | DELETE /api/vault/devices | POST /api/vault/pair | POST /api/vault/push | GET /api/ws/connect | POST /api/web/pair | POST /api/web/push | POST /api/web/register-webauthn | GET /api/web/ws/connect | GET /api/update.
- For each: headers (X-Desktop-PK, X-Signature, X-Google-Token), signed payload rule (SHA256(body) vs blobID vs raw body — record inconsistency), WS JSON examples (desktop_register, mobile_register, unlock_approved, push_relay, WAKE_UP_BIOMETRIC).
- Generate docs/OPENAPI.yaml (hand-write from router.go, or wrap with chi openapi walker) + publish Swagger UI.

Source in your repo: Vault source: internal/api/router.go | handlers.go | web_handlers.go | README.md:261-312

#45	Database Schema + Key/Secrets Spec	DO NOW — hours
-----	------------------------------------	----------------

Why: retention, DSAR deletion, and key-storage questions come up in every review. Schema is in db.go + README.

How to get it — step by step:

- Document tables from db.go:60-84 + README.md:318-347: devices(public_key UNIQUE, name, os, status, last_active, last_root_blob_id) | activity_logs capped LIMIT 50 | blobs(blob_id PK, owner_public_key, size_bytes, created_at) + RecordBlobOwnership / SetRootBlob/GetRootBlob.
- Document key storage reality: desktop onboarding.json PLAINTEXT (mnemonic + signing_key + x_secret + google tokens) + local_index.json plaintext + SharedKey in RAM + export_vault_archive copies config dir | mobile EncryptedSharedPreferences (AES256_GCM/SIV) + Keystore EC P-256 | web Dexie IndexedDB unencrypted (browser-profile only).
- Document secrets reality: oauth.rs hardcoded client_id/secret, .env.example vault_secret_123 defaults, godotenv.Load, TAURI_SIGNING key leaked in guide — mark ROTATE.

Source in your repo: Vault source: internal/db/db.go:32,43-53,60-84,133-212 | src-tauri/src/lib.rs:OnboardingConfig + oauth.rs | SecureStorageManager.kt | vault-web-auth/src/lib/db.ts | .env.example | docker-compose.yml | PRODUCTION_SETUP_GUIDE_V2.md:20-24

#46	Deployment / Production Runbook (single source)	DO NOW — hours
-----	---	----------------

Why: you have 2 conflicting guides (V2 says PASSWORD=ahs2026, TXT says blank, v0.1.1 vs 0.1.20). Buyers reject conflicts.

How to get it — step by step:

- Merge PRODUCTION_SETUP_GUIDE_V2.md (53 lines) + PRODUCTION_SETUP_GUIDE.txt (50 lines) into ONE docs/DEPLOYMENT.md.
- Include: backend :8080 + Postgres 15-alpine (docker-compose.prod.yml), env table (DATABASE_URL, GOOGLE_DRIVE_CREDENTIALS, PORT, TAURI_SIGNING_*), Tauri updater flow (tauri.conf.json endpoints https://ahs.mayfairmarketing.online/api/update, pubkey minisign 227F, GitHub Releases nsis.zip+.sig via HandleUpdate handlers.go:123), mobile debug APK (build-mobile.yml assembleDebug).
- REMOVE secrets from doc, reference GitHub Secrets / vault. Record version bump rule (tauri.conf.json + package.json + git tag v*).

Source in your repo: Vault source: PRODUCTION_SETUP_GUIDE_V2.md | PRODUCTION_SETUP_GUIDE.txt | docker-compose.prod.yml | vault-backend-go/Dockerfile | .github/workflows/build-windows.yml + build-mobile.yml | tauri.conf.json

#48	Logging & Audit Spec (draft)	DO NOW — hours
-----	------------------------------	----------------

Why: you have product activity_logs but NO immutable admin audit. Spec can be written now from current logging.

How to get it — step by step:

- Inventory current: middleware.Logger (logs IP/method/URI incl. ?public_key), hub.go:74 logs full PK+nonce (LEAK — fix to fingerprint), handlers.go:65-71 keyFingerprint() good pattern, LogThreat forgeable client-controlled subject/detail/risk.
- Specify target: who accessed which blob_id, when, from which IP, auth result, retain 12 months, append-only, no client-write, redaction rules (never log mnemonic, X-Google-Token, nonces, full PK).
- Save as docs/LOGGING_AUDIT.md. Implementation comes later.

Source in your repo: Vault source: router.go:25 | hub.go:35-41,54-75 | handlers.go:65-121,369-387,624-643,725 | db.go:70-78,146

#53-54	InfoSec Policy suite + Technical Documentation drafts	DO NOW — hours
--------	---	----------------

Why: ISO/SOC auditors accept drafts as evidence of ISMS start. Content comes from existing behaviour.

How to get it — step by step:

- Write: Access Control, HR Security, Ops, Comms, Supplier policies (1-2 pages each) reflecting actual practice (GitHub Actions, Docker, Tauri signing ceremony after rotation).
- Regenerate technical docs: expand docs/AHS_Vault_Complete_Documentation.pdf (60KB, 2026-07-23) + docs/MOBILE_FLOW_ANALYSIS.md (506 lines) + Project_Overview.txt + PROJECT.md using docs/generate_docs.py into versioned docs/ site.

Source in your repo: Vault source: docs/AHS_Vault_Complete_Documentation.pdf | docs/MOBILE_FLOW_ANALYSIS.md | docs/generate_docs.py | README.md | PROJECT.md

#55-56	Mutual NDA template + CAIQ / SIG Lite (self-answered)	DO NOW — hours
--------	---	----------------

Why: needed to share pen-test reports and start pilots. No code dependency.

How to get it — step by step:

- Download: mutual NDA (UK jurisdiction, 2-3 yr confidentiality, no licence grant) — save as legal/NDA_MUTUAL_TEMPLATE.docx.
- Download: CSA CAIQ v4 + SIG Lite template — fill from architecture + crypto + hosting answers in this PDF. Mark unknowns as 'roadmap' honestly. Save as legal/CAIQ_v4_answered.xlsx.

Source in your repo: Vault source: none — standard templates + answers from items 40-45 above.

#65p	Dependency + Secrets scans (partial evidence, runnable now)	DO NOW — hours
------	---	----------------

Why: cheapest instant security evidence. You have zero committed scan reports today.

How to get it — step by step:

- Run: cd vault-web-auth && npm audit --json > docs/scans/npm-web.json ; cd vault-desktop-tauri && npm audit --json > docs/scans/npm-desktop.json
- Run: cd vault-desktop-tauri/src-tauri && cargo audit --json > docs/scans/cargo.json (cargo install cargo-audit)
- Run: cd vault-backend-go && govulncheck ./... > docs/scans/govuln.txt (go install golang.org/x/vuln/cmd/govulncheck@latest)
- Run: gitleaks detect --source . --report-format json --report-path docs/scans/gitleaks.json (will flag the leaked Tauri key + oauth secret — expected, keep as evidence of rotation).
- Commit docs/scans/ + add to CI (.github/workflows).

Source in your repo: Vault source: package-lock.json x2 | Cargo.lock | go.mod | PRODUCTION_SETUP_GUIDE_V2.md:20-24 | oauth.rs (hardcoded secret)

PART B — Draft NOW, final only after solicitor / DPO signs

You can write these today in Word/Markdown, but a UK buyer treats them as valid ONLY with a solicitor (commercial) or DPO (privacy) sign-off. Send drafts, never claim they are 'approved'.

#9-12	EULA + MSA/Order + SLA + Acceptable Use (drafts)	DRAFT NOW — needs sign-off
How: copy a UK B2B SaaS template (governing law: England & Wales), insert: parties (your Ltd name+number), scope (relay hosting + BYO Drive — customer owns Drive data), licence (non-exclusive, non-transferable, per-seat), fees/renewal/termination, 99.9% SLA + support hours + credits, customer duties (protect mnemonic, manage Drive), IP, confidentiality, liability cap + PI insurance ref, right-to-audit + exit/return-delete. Save in legal/. Solicitor reviews liability + IP + termination. 1-2 days + review. Source in your repo: Source: README features/limits + hosting model (you-host relay + BYO Drive).		
#17-18	Privacy Notice + Cookie Policy + Customer DPA draft (Art.28)	DRAFT NOW — needs sign-off
How: Privacy Notice must list: controller (your Ltd + ICO number once registered), purposes (relay, pairing, threat log), lawful bases, recipients (Google Drive/OAuth, GitHub, VPS host), retention (from item 24), rights + DPO contact + ICO complaint. Cookie Policy for web app (list Dexie/IndexedDB + any analytics — you have Google Fonts fetch, disclose or remove). DPA must have: subject-matter/duration/nature/purpose, personal data types, obligations (act only on instructions, confidentiality, security Art.32, sub-processors, assist DSAR/breach/DPIA, delete/return, audits). Save in legal/PRIVACY_* + legal/DPA_TEMPLATE. DPO reviews. Source in your repo: Source: db.ts (IndexedDB fields) + db.go tables + shield.rs IMAP collection + index.css Fonts fetch + gdrive.go.		
#19-23	Sub-processor List + ROPA + DPIA + LIA + TRA/IDTA drafts	DRAFT NOW — needs sign-off
How: Sub-processors table today: Google Drive API + Google OAuth (US), GitHub Releases/Actions (US), VPS ahs.mayfairmarketing.online (record country/provider), Google Fonts (remove or list). ROPA (Art.30): one row per activity (pairing relay, blob relay, threat logging, IMAP shield, updater) with purpose/basis/categories/recipients/retention/security. DPIA (Art.35 — MANDATORY for biometrics + vault + mail scan): necessity, proportionality, risks (plaintext onboarding.json, full-mail fetch, token logging, US transfers), mitigations, residual risk + DPO sign. LIA for shield: purpose test, necessity test, balancing test + opt-in gate. TRA+IDTA per US transfer (UK ICO template). Source in your repo: Source: pairing/unlock flows + shield.rs:43 full RFC822 fetch + Downloads poll + Fonts import + hosting URLs.		
#24-26	Retention/Deletion + DSAR + Breach playbook drafts	DRAFT NOW — needs sign-off
How: Retention table: devices / activity_logs (e.g. 12 mo, currently LIMIT 50 read) / blobs ownership rows + Drive blobs (delete on customer request + account close, verify via Get/Delete + purge proof). DSAR: intake form, ID verify, 1-month clock, search (Postgres by public_key + Drive listing), redact third-party, response log. Breach: detect → contain (rotate keys/tokens) → assess risk → notify controller without delay → ICO within 72h if controller, subjects if high risk → log. Save in legal/ + ops/. DPO reviews. Source in your repo: Source: db.go schema + gdrive.go Upload/Get/Delete/GetBucketStats + hub/handlers logging.		
#47,49-52	Backup/Restore + Incident Response + BCP/DR + SDLC + Vuln Mgmt drafts	DRAFT NOW — needs sign-off
How: Backup: pg_dump/PITR schedule, encrypted off-site, quarterly restore test with log (today you have only postgres_data volume, no jobs — write the target + gap). IR: roles, severity, comms (customers/ICO), forensics (preserve server.log without PII), post-mortem. BCP/DR: RPO/RTO targets, failover (eu-west-2), comms. SDLC: branches, reviews, CI gates (audit/scans/tests), signing ceremony post-rotation. Vuln Mgmt: SLA (critical 7d), Dependabot/Renovate, cargo/npm/govulncheck cadence. Source in your repo: Source: docker-compose.prod.yml volumes + Dockerfile + .github/workflows + main.go timeouts.		

PART C — Do NOT chase now (needs external audit / payment / code fixes first)

Asking for these now wastes money — you will fail. Fix PART A + code gaps first, then apply in this order.

#	Document	Why blocked / lead time
---	----------	-------------------------

16	ICO Registration	ICO website, fee, 1–7 days. Do right after privacy drafts.
14-15	EV Code Signing / Apple / Play / public TLS	CAs + Apple + Google verification + payment. Needs owned domain (leave mayfairmarketing.online).
4-7	UKIPO Trademark / VAT / Insurances	UKIPO 3–4 mo. Broker/HMRC days–weeks.
28-29	Cyber Essentials → Plus	IASME. CE 1–4 wks. CE+ audited 1–3 mo. Will FAIL now (plaintext :8080, CORS *, no patch evidence).
30-32	ISO 27001 / 27701 / SOC 2 II	ISMS + auditor, 3–12 mo. Start SoA + evidence after PART A.
33	PSTI Statement	Valid only after removing defaults + fixing updater + CVD contact.
34-37	DSPT / DTAC / DCB0120-160 / G-Cloud	NHS/Gov portals + CSO hire. Weeks–months. Needs CE+, DPIA, clinical safety case.
38-39	ECJU crypto record / WCAG AA cert	ECJU weeks. DAC accessibility audit weeks.
63-64, 67-71	CREST Pen Test / Crypto Audit / Load / DR / UAT / Clinical / DSAR logs	Book AFTER fixes. Pen-test exec summary <12 mo is what buyers actually read.

Priority order for TODAY (fastest buyer value first)

- 1. **#8 LICENSE** — 15 min. Unblocks legal.
- 2. **#65p scans** — 1 hour. Only instant security evidence (npm/cargo/govulncheck/gitleaks into docs/scans/).
- 3. **#13 SBOM** — 2 hours. Procurement asks for it first.
- 4. **#44 OpenAPI + #45 schema** — half day. Needed by integrators + pen testers.
- 5. **#40-42 whitepaper + arch + DFDs** — 1–2 days. Needed for every CISO/IG call.
- 6. **#43 threat model + #48 logging spec** — half day. Shows you own the gaps.
- 7. **#46 runbook** — half day. Kill the 2-guide conflict.
- 8. **PART B drafts** — 2–3 days, then solicitor/DPO review. Do NOT present as final.

Command cheat-sheet (copy/paste)

```
cd vault-web-auth && npm audit --json > ../docs/scans/npm-web.json
cd vault-desktop-tauri && npm audit --json > ../docs/scans/npm-desktop.json
cd vault-desktop-tauri/src-tauri && cargo audit --json > ../../../../docs/scans/cargo.json
cd vault-backend-go && govulncheck ./... > ../docs/scans/govuln.txt
gitleaks detect --source . --report-path docs/scans/gitleaks.json
npx @cyclonedx/cdxgen -o docs/SBOM/sbom-web.json (per component)
Test-Path ./LICENSE / Get-ChildItem docs/scans/ # verify
```

Sources checked for this guide: README.md | PROJECT.md | Project_Overview.txt | ORIGINAL_REQUEST.md | docs/MOBILE_FLOW_ANALYSIS.md | PRODUCTION_SETUP_GUIDE_V2.md + .txt | docker-compose.prod.yml | vault-backend-go (router.go, handlers.go, web_handlers.go, db.go, webauthn.go, hub.go, gdrive.go, go.mod) | vault-desktop-tauri (crypto.rs, fs.rs, network.rs, shield.rs, oauth.rs, tauri.conf.json, Cargo.toml, package.json) | vault-web-auth (crypto.ts, db.ts, package.json) | vault-mobile-auth (CryptoManager.kt, SecureStorageManager.kt, MainActivity.kt). Full 71-item list: ENTERPRISE_DOCS_CHECKLIST.txt.